生成式 AI 安全代码评测样本库项目

可行性评估报告

报告日期：2026 年 10 月 21 日

版本：V0.1 （内部评估）

报告人：Jiaqi Geng

目录

一、项目背景与需求理解.....3

（一）客户需求概述.....3

（二）需求本质辨析.....5

（三）单个 task 的交付物清单.....5

二、可行性评估.....6

（一）总体结论.....6

（二）两类风险的技术落地路径.....6

（三）样本构造方式：自研为主、开源改编为辅.....7

（四）可运行性与可重复性保障.....8

（五）关键难点与应对措施.....8

（六）能力与团队要求.....9

三、首批 5 个样例组合建议.....9

四、风险评估与应对.....10

五、结论与建议.....11

一、项目背景与需求理解

本章先还原客户需求的完整面貌，再辨析其本质与内部前期理解的差异，最后落地为可核对的单 task 交付物清单，作为后续可行性、产能与报价评估的共同基础。

（一）客户需求概述

客户原始需求：

生成式 AI 安全代码评测需求，请评估是否能做：
1. 客户在开发静态代码扫描器，主要检测“敏感信息泄露”和“过度代理权限 / 自主行为”两类风险。先需要 5 个代码仓样本 task 做评估，后续预计扩展到几百个；按 task 报价，每个 task 是一个独立标注的仓库变体。

2. 每个样本需要一个可编译或可运行的小型仓库，包含源码、配置、固定版本的依赖、安全的合成测试数据、安全上下文说明，以及可重复得到相同结果的测试。需提供明确的构建 / 测试命令，并在干净环境验证。

3. 扫描器只看静态代码和仓库材料，不使用运行时数据；但交付仍需要可运行的测试。标准答案、风险标签、漏洞 / 修复状态、预期结果及判定依据要单独提供，不能暴露在扫描输入里。

4. 样本既要有真正存在风险的案例，也要包含部分 / 完整防护、无风险，以及容易误判的复杂负例。最好能提供同一场景的正负对照版本，只改变影响安全判断的关键条件。

5. 标注需要说明风险根因、受影响资产、完整触发路径、防护措施及有效性、剩余风险和修复建议。不能仅因为代码里有敏感信息或高权限工具就判定有漏洞，必须说明泄露或越权操作如何实际发生。

6. 需要机器可读的 JSON 元数据和稳定样本 ID，说明角色、任务范围、信任边界、允许的数据 / 操作及审批规则等。样本可自行构造或基于开源项目改编；后者需附来源、commit、许可证和修改说明，并提供审核 / 质检记录。

补充：客户要的是用于 AI 安全评测的小型、可运行的代码仓库样例：
> 每个 task 对应一个具体场景和独立标注的版本。
> 不一定是五套完整的商业项目源码。可以专门构造，也可以基于开源项目改编，文档里也允许基于同一应用做不同风险 / 防护版本。
> 目前具体交付日期和验收门槛还未确定，后续会细化。

> 请评估是否能做、月产能、单个 task 价格、5 个样例的给到时间（如果 5 个觉得比较多，告诉可提供的数量）。

概要分析：

客户正在开发一款面向生成式 AI 应用代码的静态代码扫描器，核心检测两类风险：一是**敏感信息泄露**（secrets leakage / data exposure），二是**过度代理权限与自主行为**（excessive agency / autonomous action）。为评测该扫描器的检出能力与误报控制水平，客户需要一套高质量的评测基准样本库：每个 task 对应一个具体场景，是一个独立标注的仓库变体；首期为 5 个样本用于评估合作方能力，后续预计扩展至几百个。

每个样本的交付要求可归纳为四个层面：

- **可运行层**：一个可编译或可运行的小型代码仓库，包含源码、配置、固定版本的依赖、安全的合成测试数据、安全上下文说明，以及可重复得到相同结果的测试，并附明确的构建 / 测试命令，在干净环境中验证通过。
- **标注层**：标准答案、风险标签、漏洞 / 修复状态、预期结果及判定依据，单独提供，不得暴露在扫描输入中。标注需说明风险根因、受影响资产、完整触发路径、防护措施及有效性、剩余风险和修复建议。
- **设计层**：样本须覆盖真阳性（真实风险）、部分防护、完整防护、无风险以及容易误判的复杂负例；最好提供同一场景的正负对照版本，只改变影响安全判断的关键条件。
- **元数据层**：机器可读的 JSON 元数据与稳定样本 ID，说明角色、任务范围、信任边界、允许的数据 / 操作及审批规则；样本可自研构造或基于开源项目改编，后者需附来源、commit、许可证、修改说明及审核 / 质检记录。

（二）需求本质辨析

内部前期理解将该需求定位为"为扫描器提供训练数据"，这一理解方向基本正确（寻找合适的开源项目并定向修改代码以触发两类风险），但有两处关键偏差需要修正：

其一，**这不是训练数据，而是评测基准（测试集）**。训练数据可以容忍一定比例的标注噪声，而评测样本的标注答案就是金标准（ground truth）——任何一处错误标注都会直接污染客户扫描器的评测指标，进而引发验收争议。因此本项目的成败核心在于**标注质量与判定严谨性**，而非产出数量，质量门槛显著高于普通数据标注业务。

其二，**"注入风险"只是手段之一，不是全部**。客户明确要求样本包含正例、负例、部分防护和复杂负例，并且要求判定必须基于"泄露或越权如何实际发生"的完整触发路径。这意味着大量工作在于**威胁建模与可控实验设计**（例如同一场景下只改变"密钥来源"或"审批开关"一个条件），单纯的代码改写能力不足以支撑交付。

> **定位修正：**本项目应按"安全评测基准数据集构建"立项，而非通用数据标注——人员配置、质量流程与定价逻辑均以安全工程能力为基准。

（三）单个 task 的交付物清单

序号	交付物	说明
1	代码仓库（扫描输入包）	源码、配置、固定版本依赖清单、合成测试数据、安全上下文说明（不含任何答案信息）
2	构建 / 测试说明	明确的构建与测试命令，附干净环境（Docker/CI）验证记录

序号	交付物	说明
3	可重复测试	固定随机种子、mock 外部服务，保证相同输入得到相同结果
4	标注答案包（独立交付）	风险标签、漏洞 / 修复状态、根因、受影响资产、触发路径、防护有效性、剩余风险、修复建议
5	JSON 元数据	稳定样本 ID、角色、任务范围、信任边界、允许的数据 / 操作、审批规则
6	溯源与质检记录	自研说明，或开源来源 URL、commit、许可证、修改说明、双人质检记录

二、可行性评估

本章从总体结论、风险落地路径、构造方式、可运行性保障、关键难点与团队能力六个方面论证项目的可承接性，并识别必须提前控制的难点。

（一）总体结论

本项目可以承接。该需求属于"安全工程 + 评测数据集构建"的交叉领域，技术路线清晰、无不可克服的障碍；但它与常规数据标注业务的能力模型差异较大，核心依赖**具备威胁建模能力的安全工程人员**，而非通用标注人力。建议以小型专项小组形式承接，并采用"首批试点 + 滚动扩产"的合作节奏。

（二）两类风险的技术落地路径

风险类别	典型可注入场景	静态可判定性

风险类别	典型可注入场景	静态可判定性
敏感信息泄露	硬编码 API 密钥 / 数据库口令并随仓库提交；日志与异常堆栈中输出用户 PII；LLM 应用将用户数据拼入 prompt 或写入对话日志；工具返回结果未脱敏即存储 / 回显；`.env` 等配置文件误入版本控制	高，均有成熟模式
过度代理权限 / 自主行为	Agent 具备任意 shell 执行权限且无审批环节；文件系统全盘读写且无路径白名单；自主循环缺少终止 / 熔断条件；声明的权限边界与实际代码不一致；工具权限声明缺失导致可被间接 prompt 注入滥用	中高，需精心设计使风险可从静态材料推断

两类风险均有大量公开研究（OWASP LLM Top 10、MITRE ATLAS 等）与真实漏洞模式可供参照，场景库设计不存在原创性障碍。

（三）样本构造方式：自研为主、开源改编为辅

- **自研构造（建议占比 60% - 70%）**：构造千行级小型仓库（如一个带工具调用的 LLM 客服应用、一个数据处理脚本服务），体量可控、风险点位置精确、正负对照实现成本最低，是负例与对照样本的首选载体。
- **开源项目改编（建议占比 30% - 40%）**：选取 MIT / Apache-2.0 等宽松许可证的小型真实项目，在其上注入或修复风险点，提升样本真实感。需逐项完成许可证审查、来源与 commit 锁定、修改说明文档，规避 GPL 等传染性许可证项目。

两种方式均在客户需求允许范围内，混合使用可在质量、真实感与成本之间取得平衡。

（四）可运行性与可重复性保障

- **依赖固定**：以 lockfile（`requirements.txt` 精确版本 / `package-lock.json`）锁定依赖，必要时提供 Dockerfile；
- **合成数据**：全部使用伪造密钥与合成 PII，杜绝任何真实凭据与个人信息进入样本；
- **确定性测试**：外部 API 一律 mock，随机过程固定种子，保证干净环境（容器/全新 CI runner）中"相同命令得到相同结果"；
- **验证流程**：交付前在全新容器中执行一次完整构建＋测试流水线，留存验证记录。

（五）关键难点与应对措施

难点	具体表现	应对措施
判定严谨性	客户要求不能仅因"出现敏感信息或高权限工具"即判漏洞，必须给出泄露 / 越权的实际发生路径	标注人员须具备安全研究背景；建立标注规范（含判定模板与反例清单）；双人交叉标注＋第三人仲裁
静态可判定边界	扫描器只看静态代码与仓库材料，标注必须确保风险仅凭静态材料可推断，运行时验证仅作交叉佐证	场景设计阶段即审查"静态可推断性"，不可静态判定的场景一律剔除
答案与输入隔离	标准答案若混入仓库材料，即造成"泄题"，评测失效	交付分为"扫描输入包"与"答案包"两个物理分离的产物；建立发布前自动检查（扫描输入包中不得出现答案文件、标签关键词）
验收标准未定	客户尚未确定验收门槛与交付日期，存在返工风险	首批采取"场景设计文档先行评审、确认后再构造"的里程碑机制，将返工控制在设计阶段

难点	具体表现	应对措施
正负对照设计	需要精确控制变量，只改变影响安全判断的关键条件	建立对照变体的代码 diff 审查清单，确保条件外零差异

（六）能力与团队要求

按月产能 3-4 个 task，承接本项目所需的最小团队配置为：**1 名项目经理兼代码开发兼质检，1 名代码开发工程师**（按 Python+JS 评估，若有其他语言要求需要增加工程师数量）。

三、首批 5 个样例组合建议

编号	风险类别	样本设计	档位
T1	敏感信息泄露	真阳性：LLM 客服应用将用户 PII 写入对话日志且日志对外可读	标准
T2	敏感信息泄露	正负对照：同一应用，负例为密钥硬编码入库，正例改为环境变量读取＋密钥轮换，仅此条件不同	复杂
T3	过度代理权限	真阳性：Agent 可无审批执行任意 shell 命令，且命令参数来源于不可信输入	标准
T4	过度代理权限	复杂负例：存在高权限工具，但受路径白名单＋人工审批＋沙箱三重约束，预期为无风险	标准

编号	风险类别	样本设计	档位
T5	混合	基于开源项目改编：含部分防护的剩余风险场景（防护措施存在但有绕过路径），附完整溯源	复杂

该组合覆盖两类风险、真阳性 / 负例 / 复杂负例 / 正负对照、自研与开源改编两种来源，能完整展示承接能力，也便于客户据此细化后续数百个样本的需求规格。

四、风险评估与应对

风险	影响	等级	应对措施
验收标准与交付日期未定	范围蔓延、返工、商务争议	高	立项后第一周与客户共同冻结验收框架；首批采用 M1 设计评审确认机制
标注判定争议	客户不认可"实际发生路径"论证，样本被判无效	高	标注规范先行；双人标注＋仲裁；判定依据引用公开标准（OWASP LLM Top 10 等）增强权威性
答案泄题	答案信息混入扫描输入，样本报废	中	双包物理分离＋发布前自动化检查
开源许可证合规	侵权或交付受阻	中	许可证白名单制度，逐项目审查并留档
产能爬坡不及预期	后续大批量订单交付延期	中	模板库沉淀＋按订单滚动扩产，避免承诺超出稳态产能的排期

五、结论与建议

结论：本项目可承接。核心能力依赖安全工程（威胁建模、代码审计）而非通用标注，建议以专项小组形式按"首批试点 + 滚动扩产"节奏推进。

核心结论数字汇总如下：

可行性结论	1 样例交付	5 样例交付	月产能	单个 task 报价
可承接	**12 工作日**	**40 工作日**	**4–10 个 task (按 2-5 人评估)**	**首个 task 1.8 万，2-5 个 task 约 1 万/个 后续量大可再降**

配套建议：

1. **试点先行：**以第三章的 5 样本组合作为试点方案报价，试点验收通过后再谈数百个规模的框架协议与阶梯价格；
2. **SOW 尽早冻结：**将复杂度分档定义、语言覆盖、验收门槛、返工与仲裁条款、知识产权归属写入 SOW，当前价格仅为估算，上述变量对价格敏感；
3. **标注规范先行：**立项第一周产出标注判定规范与答案包模板，提交客户确认口径，这是控制最大风险（判定争议）的杠杆；
4. **隔离机制制度化：**扫描输入包与答案包的双包分离和自动化检查，从第一批开始就是硬流程；
5. **滚动扩产：**后续数百个规模的产能以模板复用＋渐进招人实现。